



CyberScan
Security Audit Platform

audit-multivuln.cyberscan.local — Procédure de Résolution des Vulnérabilités

Informations générales

Information	Valeur
Date et heure du scan	20/07/2026 à 15:02
Identifiant unique du scan	64
Client	chaima

NIVEAU DE RISQUE : CRITIQUE
Score de risque IA : 8.7/10 — Score sécurité : 1.3/10

Le score sécurité est l'inverse du score de risque : plus il est bas, plus le niveau de vulnérabilité est élevé.

Document confidentiel — Usage interne uniquement

Sommaire

Informations générales	1
Situation actuelle	3
Fiches vulnérabilité	4
Plan de correction	8
Annexe CVE	8
Conclusion	8

Situation actuelle

L'audit de audit-multivuln.cyberscan.local a identifié 7 vulnérabilité(s) significative(s). OS/versions détectés : Nginx (1.20.0), Country (FRANCE), IP (192.0.2.63).

■ 2. Méthodologie

SSLScan — Inventaire des protocoles et suites cryptographiques TLS.

Nmap — Détection des ports ouverts, services et bannières réseau.

OpenSSL — Contrôle de la négociation TLS et du certificat présenté.

WhatWeb — Identification des technologies et versions web.

OWASP ZAP — Analyse dynamique des contrôles de sécurité HTTP.

NVD — Corrélation des produits versionnés avec les CVE du NIST.

■ 3. Inventaire technique

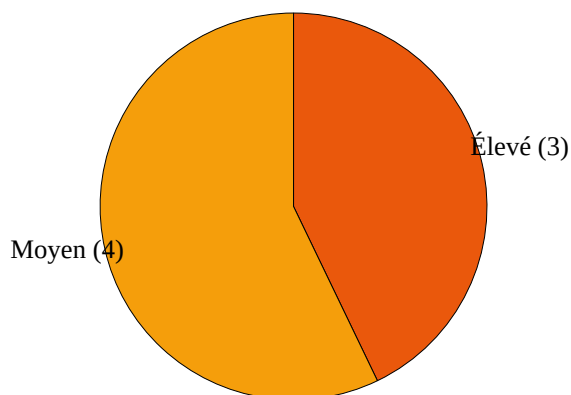
Technologies détectées

Technologie	Version	Détails
Nginx	1.20.0	Server: nginx/1.20.0
Country	—	FRANCE
IP	—	192.0.2.63

Ports exposés

Port	État	Service	Classification
80/tcp	open	http	Standard
443/tcp	open	https	Standard

■ 4. Indicateurs graphiques



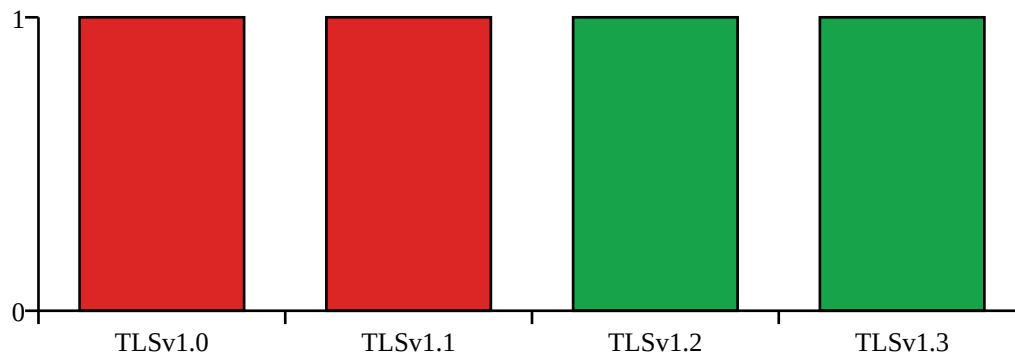
Répartition des vulnérabilités par sévérité

Total : 7 vulnérabilité(s) significative(s)

Jauge du score de risque IA



Statut des protocoles SSL/TLS



Fiches vulnérabilité

Vuln_001

Libellé	Valeur
Identifiant	Vuln_001
Composant vulnérable	Nginx
Preuve d'audit	WhatWeb/NVD : Nginx A security issue in nginx resolver may allow an attacker able to forge UDP packets from the DNS server to cause a 1-byte memory overwrite.
Type	Technique
Actif impacté	audit-multivuln.cyberscan.local
Score CVSS	7.7
Niveau de criticité	Élevé
Recommandation	Mettre à jour Nginx vers une version corrigée référencée par CVE-2021-23017.
Priorité de mise en œuvre	Immédiate

Solution proposée :

1. Identifier le paquet exact et sauvegarder sa configuration.
2. Exécuter « apt update && apt install --only-upgrade <paquet> ».
3. Redémarrer le service, vérifier sa version et rejouer les tests de sécurité.

Vuln_002

Libellé	Valeur
Identifiant	Vuln_002
Composant vulnérable	TLSv1.0 / TLSv1.1
Preuve d'audit	TLSv1.0 enabled TLSv1.1 enabled
Type	Configuration
Actif impacté	audit-multivuln.cyberscan.local
Score CVSS	7.5
Niveau de criticité	Élevé
Recommandation	Désactiver TLS 1.0 et TLS 1.1 et n'autoriser que TLS 1.2/1.3.
Priorité de mise en œuvre	Immédiate

Solution proposée :

1. Nginx : définir « ssl_protocols TLSv1.2 TLSv1.3; » dans le bloc serveur.
2. Apache : définir « SSLProtocol -all +TLSv1.2 +TLSv1.3 » puis recharger le service.
3. Vérifier avec « openssl s_client -connect <hôte>:443 -tls1 » puis relancer sslscan.

Vuln_003

Libellé	Valeur
Identifiant	Vuln_003
Composant vulnérable	Suites de chiffrement faibles (3DES/RC4)
Preuve d'audit	Accepted TLS_RSA_WITH_3DES_EDE_CBC_SHA
Type	Configuration
Actif impacté	audit-multivuln.cyberscan.local
Score CVSS	7.5
Niveau de criticité	Élevé
Recommandation	Retirer 3DES et RC4 de la liste des suites cryptographiques autorisées.
Priorité de mise en œuvre	Immédiate

Solution proposée :

1. Nginx : utiliser « ssl_ciphers HIGH:!aNULL:!MD5:!3DES:!RC4; ».
2. Apache : utiliser « SSLCipherSuite HIGH:!aNULL:!MD5:!3DES:!RC4 » puis recharger le service.
3. Relancer « sslscan <hôte> » et confirmer l'absence de 3DES/RC4.

Vuln_004

Libellé	Valeur
Identifiant	Vuln_004
Composant vulnérable	En-tête Content-Security-Policy (CSP) absent
Preuve d'audit	ZAP [Medium] En-tête Content-Security-Policy (CSP) absent URL : https://audit-multivuln.cyberscan.local Occurrences : 1
Type	Technique
Actif impacté	https://audit-multivuln.cyberscan.local
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Configurer explicitement l'en-tête HTTP Content-Security-Policy sur toutes les réponses.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Nginx : add_header Content-Security-Policy "default-src 'self'; object-src 'none'; frame-ancestors 'self'" always;
2. Apache : Header always set Content-Security-Policy "default-src 'self'; object-src 'none'; frame-ancestors 'self'"
3. Vérifier avec « curl -I https://<hôte> » que Content-Security-Policy est présent.

Vuln_005

Libellé	Valeur
Identifiant	Vuln_005
Composant vulnérable	Attribut Subresource Integrity (SRI) absent
Preuve d'audit	ZAP [Medium] Attribut Subresource Integrity (SRI) absent URL : https://audit-multivuln.cyberscan.local Occurrences : 2
Type	Technique
Actif impacté	https://audit-multivuln.cyberscan.local
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Fournir un attribut integrity valide sur chaque balise script ou link chargée depuis un tiers.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Nginx : déployer la balise « <script src="/app.js" integrity="sha384-..." crossorigin="anonymous"></script> » dans le fichier HTML servi.
2. Apache : déployer la même balise SRI dans le document servi par le VirtualHost.
3. Générer le hash avec « openssl dgst -sha384 -binary fichier.js | openssl base64 -A », puis vérifier dans la console du navigateur.

Vuln_006

Libellé	Valeur
Identifiant	Vuln_006
Composant vulnérable	Configuration CORS non sécurisée
Preuve d'audit	ZAP [Medium] Configuration CORS non sécurisée URL : https://audit-multivuln.cyberscan.local Occurrences : 1
Type	Technique
Actif impacté	https://audit-multivuln.cyberscan.local
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Limiter CORS aux origines, méthodes et en-têtes strictement nécessaires.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Nginx : « add_header Access-Control-Allow-Origin "https://app.exemple" always; » sans réflexion dynamique de Origin.
2. Apache : « Header always set Access-Control-Allow-Origin "https://app.exemple" ».
3. Vérifier avec « curl -I -H "Origin: https://origine-inconnue.test" https://<hôte> » que l'origine est refusée.

Vuln_007

Libellé	Valeur
Identifiant	Vuln_007
Composant vulnérable	Directive Cache-Control insuffisante
Preuve d'audit	ZAP [Medium] Directive Cache-Control insuffisante URL : https://audit-multivuln.cyberscan.local Occurrences : 1
Type	Technique
Actif impacté	https://audit-multivuln.cyberscan.local
Score CVSS	5.0
Niveau de criticité	Moyen
Recommandation	Interdire la mise en cache des réponses contenant des données sensibles.
Priorité de mise en œuvre	Court terme

Solution proposée :

1. Nginx : « add_header Cache-Control "no-cache, no-store, must-revalidate, private" always; ».
2. Apache : « Header always set Cache-Control "no-cache, no-store, must-revalidate, private" ».
3. Vérifier avec « curl -I https://<hôte>/<ressource-sensible> ».

Plan de correction

Priorité	Élément	Action corrective
P1	CVE-2021-23017	Mettre à jour Nginx vers une version corrigée référencée par CVE-2021-23017.
P1	—	Désactiver TLS 1.0 et TLS 1.1 et n'autoriser que TLS 1.2/1.3.
P1	CVE-2016-2183	Retirer 3DES et RC4 de la liste des suites cryptographiques autorisées.
P2	—	Configurer explicitement l'en-tête HTTP Content-Security-Policy sur toutes les réponses.
P2	—	Fournir un attribut integrity valide sur chaque balise script ou link chargée depuis un tiers.
P2	—	Limiter CORS aux origines, méthodes et en-têtes strictement nécessaires.
P2	—	Interdire la mise en cache des réponses contenant des données sensibles.

Annexe CVE

CVE / Élément	CVSS	Description
—	—	Aucune autre CVE pertinente après filtrage.

Conclusion

Le score sécurité est de 1.3/10, pour un risque critique (8.7/10). Appliquer les actions P1/P2 puis relancer CyberScan.

■ Annexe — sorties brutes complètes

SSLScan

```
SSL/TLS Protocols:
TLSv1.0 enabled
TLSv1.1 enabled
TLSv1.2 enabled
TLSv1.3 enabled
Accepted TLS_RSA_WITH_3DES_EDE_CBC_SHA
```

Nmap

```
Nmap scan report for audit-multivuln.cyberscan.local
PORT STATE SERVICE VERSION
80/tcp open  http  nginx 1.20.0
443/tcp open  https  nginx 1.20.0
```

OpenSSL

```
CONNECTED
Protocol: TLSv1.3
Cipher: TLS_AES_256_GCM_SHA384
```

WhatWeb

```
{
  "success": true,
  "technologies": [
    {
      "name": "Nginx",
      "version": [
        "1.20.0"
      ],
      "string": [
        "Server: nginx/1.20.0"
      ]
    },
    {
      "name": "Country",
      "version": [],
      "string": [
        "FRANCE"
      ]
    },
    {
      "name": "IP",
      "version": [],
      "string": [
        "192.0.2.63"
      ]
    }
  ]
}
```

OWASP ZAP

```
[
  {
    "url": "https://audit-multivuln.cyberscan.local",
    "name": "Content Security Policy (CSP) Header Not Set",
    "risk": "Medium",
    "count": 1,
    "solution": "Ensure CSP is set."
  },
  {
    "url": "https://audit-multivuln.cyberscan.local",
    "name": "Sub Resource Integrity Attribute Missing",
```

```

"risk": "Medium",
"count": 2,
"solution": "Provide a valid integrity attribute to the tag."
},
{
"url": "https://audit-multivuln.cyberscan.local",
"name": "CORS Misconfiguration",
"risk": "Medium",
"count": 1,
"solution": "Ensure CORS is configured securely."
},
{
"url": "https://audit-multivuln.cyberscan.local",
"name": "Cache-control is not set properly",
"risk": "Medium",
"count": 1,
"solution": "Set Cache-Control."
}
]

```

NVD

```

[
{
"cve_id": "CVE-2021-23017",
"cvss_score": 7.7,
"severity": "HIGH",
"technologies": [
"Nginx"
],
"description": "A security issue in nginx resolver may allow an attacker able to forge UDP packets from the DNS server to cause a 1-byte memory overwrite.",
"matched_cpe": "cpe:2.3:a:f5:nginx:1.20.0:*:*:*:*:*:*:*",
"cpe_verified": true
}
]

```

Preuves techniques complètes disponibles en export JSON depuis l'historique des scans (scan ID : 64)